

Incident Response & Security Breach Simulation

Primary Tools Used: Linux Logs (/var/log/auth.log)

Incident Simulation:

Simulated a security incident on **Metasploitable 2** by performing repeated failed SSH login attempts:

Manual incorrect password entries

Targeted both invalid and valid usernames (ceo, crackl, lack, msfadmin)

Source IP: **192.168.136.128**

This generated realistic authentication failure logs.

Detection & Analysis:

Logs analysed using:

```
sudo grep "Failed password" /var/log/auth.log
```

```
msfadmin@metasploitable:~$ sudo grep "Failed password" /var/log/auth.log
[sudo] password for msfadmin:
Feb 13 05:12:59 metasploitable sshd[7021]: Failed password for invalid user ceo
from 192.168.136.128 port 53166 ssh2
Feb 13 05:13:23 metasploitable sshd[7026]: Failed password for invalid user crackl
from 192.168.136.128 port 41454 ssh2
Feb 13 05:13:30 metasploitable sshd[7026]: Failed password for invalid user crackl
from 192.168.136.128 port 41454 ssh2
Feb 13 05:14:03 metasploitable sshd[7028]: Failed password for invalid user lack
from 192.168.136.128 port 59996 ssh2
Feb 14 03:49:22 metasploitable sshd[5305]: Failed password for msfadmin from 192
.168.136.128 port 33018 ssh2
Feb 14 03:49:47 metasploitable sshd[5308]: Failed password for msfadmin from 192
.168.136.128 port 50710 ssh2
Feb 14 03:50:17 metasploitable sshd[5310]: Failed password for msfadmin from 192
.168.136.128 port 35666 ssh2
Feb 14 03:53:21 metasploitable sudo: msfadmin : TTY=pts/1 ; PWD=/home/msfadmin ;
USER=root ; COMMAND=/bin/grep Failed password /var/log/auth.log
msfadmin@metasploitable:~$
```

Extracted Log Entries:

Feb 13 05:12:59 Failed password for invalid user ceo from 192.168.136.128
Feb 13 05:13:23 Failed password for invalid user crackl from 192.168.136.128
Feb 13 05:14:03 Failed password for invalid user lack from 192.168.136.128
Feb 14 03:49:22 Failed password for msfadmin from 192.168.136.128
Feb 14 03:49:47 Failed password for msfadmin from 192.168.136.128
Feb 14 03:50:17 Failed password for msfadmin from 192.168.136.128

Observations:

Multiple usernames attempted → indicates automated brute-force behaviour

Repeated attempts on valid account msfadmin

All attempts originated from **same source IP**

Incident Classification:

Field	Details
Attack Type	SSH Brute Force / Credential Guessing
Target	Metasploitable 2 SSH Service (Port 22)
Source IP	192.168.136.128
Severity	Medium (no successful login gained)
Technique	Repeated failed login attempts, username enumeration

Containment Actions:

Identified malicious source IP: 192.168.136.128
simulated firewall block:

```
sudo iptables -A INPUT -s 192.168.136.128 -j DROP
```

Verified no successful login occurred during simulation

Eradication & Root Cause Fix:

- Changed password for msfadmin
- Confirmed no active unauthorized sessions
- Reviewed SSH configuration:
PermitRootLogin no
PasswordAuthentication yes (temporary for lab)
- Root cause: Automated brute-force attempts on legacy lab environment; weak password attempts

Restore Secure State:

- Enforced strong password policy for SSH accounts
- Recommended future mitigations include account lockout and automated intrusion prevention

Incident Timeline:

Date	Time	Event
Feb 13	05:12	Failed login attempt for ceo
Feb 13	05:13	Failed login attempt for crackl
Feb 13	05:14	Failed login attempt for lack
Feb 14	03:49	Failed login attempt for msfadmin
Feb 14	03:50	Repeated failed attempts for msfadmin

Preventive Recommendations:

- Enforce strong password policy (already done in lab)
- Implement account lockout after multiple failed login attempts

- Disable weak SSH cryptographic algorithms (ssh-dss, old MACs)
- Enforce SSH key-based authentication
- Monitor authentication logs regularly
- Consider SIEM solution such as TheHive for centralized incident management